

TECHNICAL DETAIL

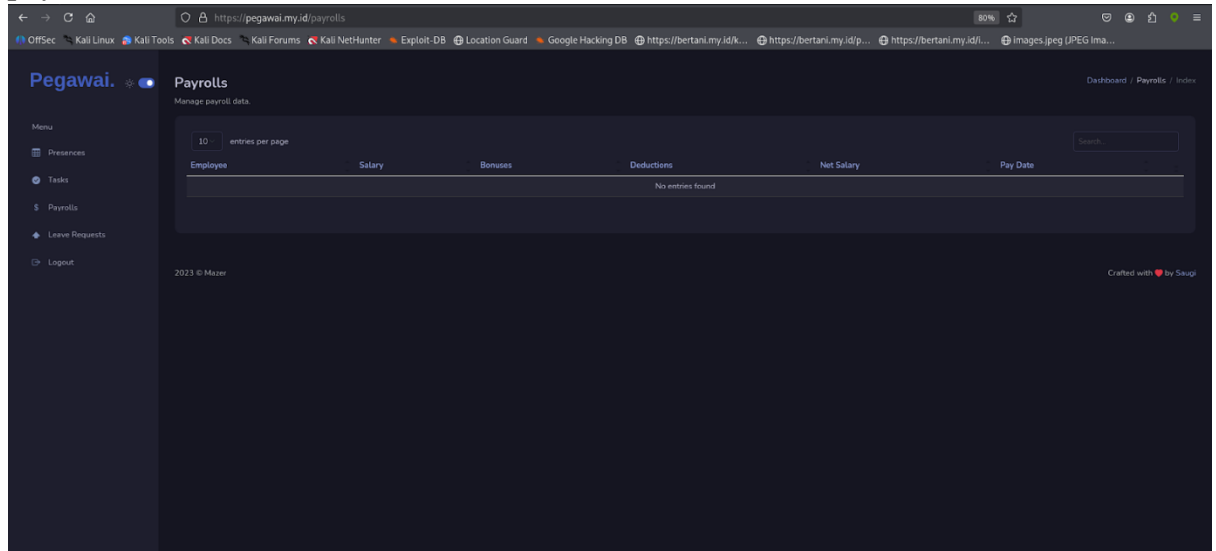
Title	Broken Access Control: Insecure Direct Object Reference (IDOR) on Payroll Editing
Reporter	Daffa Rahadya Atmawiguna (rahadya.daffaa@gmail.com)
Date	2025-12-28
Affected Asset	https://pegawai.my.id/payrolls/edit/{id}
Severity	High
CVSS Score	8.1 (CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:N)
Proof of Concepts	Please see Steps to Reproduce section

SUMMARY

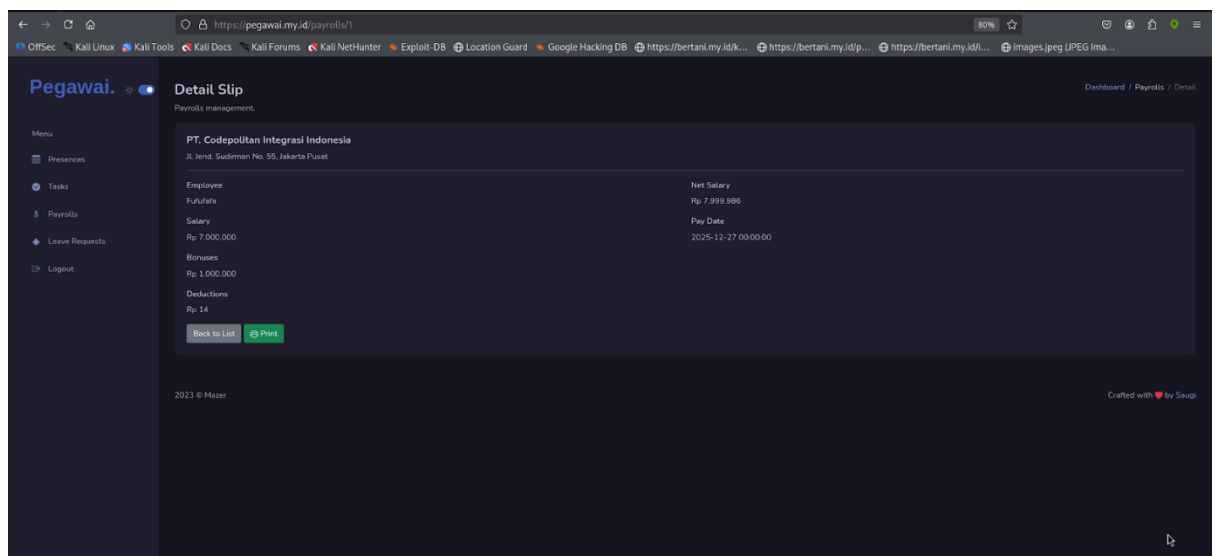
Ditemukan kerentanan Broken Access Control berjenis Insecure Direct Object Reference (IDOR) pada fungsi pengeditan data gaji (*Payroll Editing*) di platform pegawai.my.id. Pengguna dengan tingkat akses rendah (peran *developer*) dapat memodifikasi rincian finansial karyawan lain, termasuk gaji pokok, bonus, dan potongan, hanya dengan mengakses URL pengeditan secara langsung melalui manipulasi ID. Kegagalan validasi otoritas di sisi server ini memungkinkan terjadinya manipulasi data finansial yang sah secara tidak sah.

STEPS TO REPRODUCE

1. Login ke akun Anda yang memiliki role developer
2. Buka url <https://pegawai.my.id/payrolls> disini terlihat tidak ada fitur edit payrolls



3. Lalu tambahkan /payrolls/{id} di url menjadi <https://pegawai.my.id/payrolls/1> dalam contoh kali ini saya masukan 1 . maka anda bisa melihat slip milik user lain



4. Lalu kita tinggal tambahkan /edit dibelakang url nya menjadi <https://pegawai.my.id/payrolls/1/edit> dan ubah salary bonuses, deductions net salary , dan pay date

Pegawai. Payrolls

Manage payroll data.

Employee: Futufata

Salary: 1

Bonuses: 1

Deductions: 14.00

Net Salary: 1

Pay Date: 2025-12-31 00:00:00

[Update Payroll](#)

2023 © Mazer

Crafted with ❤️ by Saugi

5. Login ke akun dummy yang menjadi target maka data telah berubah

Sebelum:

Pegawai. Payrolls

Manage payroll data.

10 entries per page

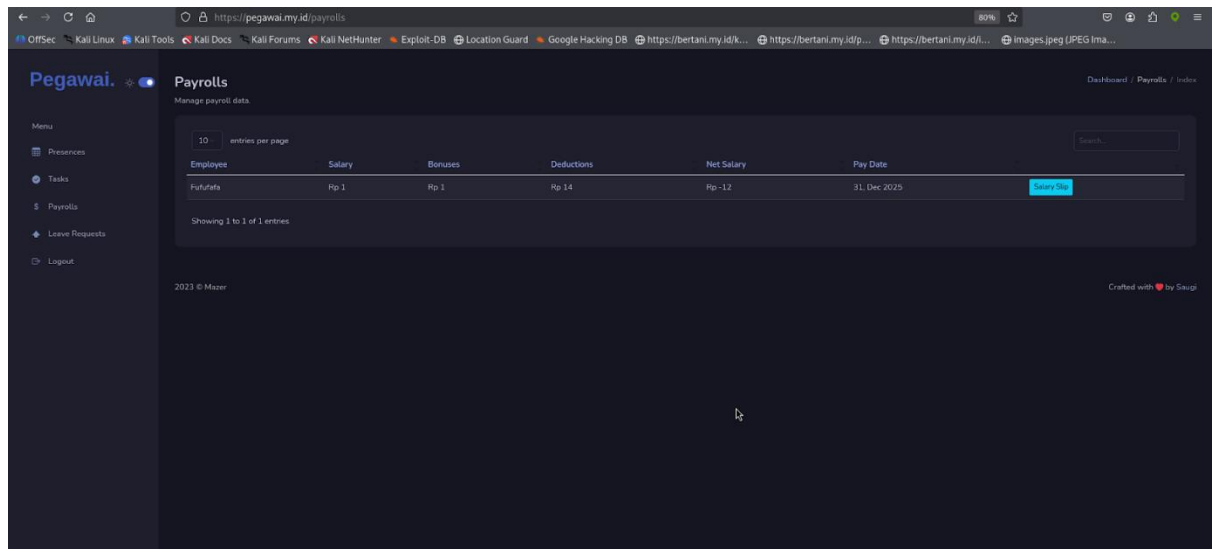
Employee	Salary	Bonuses	Deductions	Net Salary	Pay Date	
Futufata	Rp 7.000.000	Rp 1.000.000	Rp 14	Rp 7.999.986	27. Dec 2025	Salary Slip

Showing 1 to 1 of 1 entries

2023 © Mazer

Crafted with ❤️ by Saugi

Sesudah:



EXPECTED RESULT

1. Akses ke halaman pengeditan slip gaji (/payrolls/{id}/edit) seharusnya dibatasi hanya untuk staf keuangan atau administrator yang berwenang.
2. Pengguna yang mencoba mengakses atau mengubah data milik orang lain tanpa hak akses administratif seharusnya menerima respons **403 Forbidden**.

ACTUAL RESULT

1. Aplikasi mengizinkan akses penuh ke formulir pengeditan milik siapa pun hanya melalui manipulasi ID di URL tanpa pengecekan kepemilikan data di sisi server.
2. Penyerang dapat melihat dan mengubah data sensitif seperti nominal gaji bersih, bonus, rincian potongan, hingga tanggal pembayaran karyawan lain secara langsung.

IMPACT

1. **Financial Integrity Loss:** Kemampuan untuk memanipulasi angka gaji dan bonus secara ilegal yang dapat menyebabkan kerugian finansial nyata bagi perusahaan.
2. **Privacy Violation:** Pelanggaran privasi berat melalui paparan dan modifikasi data finansial pribadi karyawan tanpa izin.
3. **Business Logic Bypass:** Melewati kebijakan internal perusahaan mengenai kewenangan pengelolaan data penggajian.

RECOMMENDATION

1. **Object-Level Authorization:** Terapkan pengecekan otoritas pada fungsi edit dan update di dalam *Payroll Controller* untuk memastikan pengguna hanya dapat mengubah data yang menjadi wewenangnya.
2. **Implementasi Laravel Policies:** Gunakan fitur *Policies* untuk mendefinisikan aturan otorisasi yang ketat pada setiap aksi pengolahan data (CRUD).
3. **Server-Side Validation:** Pastikan data finansial yang dikirimkan divalidasi ulang di sisi server terhadap identitas pembuat permintaan sebelum disimpan ke database.

REFERENCES

1. **OWASP Top 10 - A01:2021 Broken Access Control:**
https://owasp.org/Top10/A01_2021-Broken_Access_Control/
2. **CWE-639: Authorization Bypass Through User-Controlled Key:**
<https://cwe.mitre.org/data/definitions/639.html>